

Clase 335 — Explotación y post-explotación autorizada asistida por IA

Parte: **18 — IA aplicada a la ciberseguridad** · Fuente: kali-mcp (MIT) · PTES · MITRE ATT&CK 

Duración estimada: **110 min** · Nivel: **Avanzado**

 **Autorización obligatoria.** La explotación solo es legal contra sistemas propios o con permiso escrito dentro de un alcance definido. Esta clase es **metodológica**: cómo supervisar a un agente que asiste en explotación, no un recetario de ataque. La decisión de explotar y la responsabilidad son **siempre humanas**.

Objetivo

Comprender el rol —y los **límites**— de un agente de IA en las fases de explotación y post-explotación de un pentest autorizado: la IA **propone y documenta**, el profesional **decide y ejecuta** las acciones con impacto. El foco es la supervisión, la trazabilidad y por qué nunca se deben delegar a la IA decisiones destructivas o de alcance.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

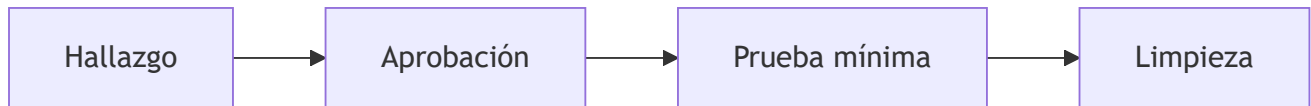
- 1. **Situar** el papel del agente: sugerir vectores, no decidir explotarlos.
- 2. **Aplicar** un modelo de aprobación humana para toda acción con impacto.
- 3. **Exigir** trazabilidad completa (qué se ejecutó, cuándo, con qué resultado).
- 4. **Reconocer** los riesgos: acción destructiva, salir de alcance, daño colateral.
- 5. **Documentar** la explotación de forma reproducible para el informe.

Temas

#	Tema	Por qué importa
1	La IA propone, el humano dispone	Evita acciones no autorizadas o irreversibles.
2	Aprobación por acción sensible	Explotar, escribir o borrar exige confirmación explícita.
3	Trazabilidad y logging	Un pentest debe ser auditable; la IA no borra huellas.
4	Post-explotación con límites	Prueba de impacto sin causar daño ni tocar datos reales.
5	Reproducibilidad	Cada paso debe poder repetirse manualmente.

Explicación en profundidad

La explotación asistida aumenta velocidad y riesgo de daño. Se exige prueba mínima, aprobación por etapa, límites de efecto, deconfliction y cleanup. La capacidad de generar un payload no constituye autorización para ejecutarlo.



El diagrama separa lenguaje de autoridad. El modelo puede proponer; la política determina si la operación pertenece al alcance; la herramienta produce evidencia; y una persona o control determinista decide transiciones de alto impacto. Se registran prompt relevante, parámetros validados, versión, salida, aprobador y cleanup sin almacenar secretos innecesarios.

Caso razonado

El objetivo se demuestra con lectura de un marcador. El agente no descarga datos reales ni busca persistencia.

Glosario operativo

Término	Definición
Proof of impact	Evidencia mínima suficiente del efecto autorizado.
Guardrail	Capa que reduce una capacidad o detecta su uso; no garantía absoluta.
Audit trail	Registro ordenado de solicitudes, decisiones, ejecuciones y resultados.

Criterio de dominio

El alumno demuestra dominio cuando reproduce el flujo completo, puede atribuir cada acción, evita que texto no confiable otorgue autoridad y explica qué control contiene un fallo del modelo.

Definiciones y características

Supervisión humana (human-in-the-loop) : Toda acción con impacto pasa por aprobación de una persona antes de ejecutarse. Es el control central de esta clase.

Prueba de concepto (PoC) controlada : Demostrar que una vulnerabilidad es explotable con el mínimo impacto necesario (p. ej. un `whoami`), sin escalar daño.

Trazabilidad : Registro completo y ordenado de cada acción, comando y resultado, imprescindible para el informe y para la responsabilidad legal.

Alcance de post-explotación : Lo que el engagement permite hacer tras obtener acceso (enumerar, demostrar impacto) y lo que **no** (exfiltrar datos reales, pivotar fuera de alcance).

Herramientas y preparación

kali-mcp contra una VM vulnerable **tuya** (p. ej. Metasploitable/DVWA en red aislada). El agente puede sugerir vectores; tú apruebas y ejecutas. Mantén un registro de la sesión.

Laboratorio guiado

Solo contra tu VM, con un alcance escrito que tú mismo definas para el ejercicio.

1. **Priorización de vectores.** Pide al agente que, a partir del recon, priorice posibles vías de entrada **sin ejecutarlas**. Revisa su razonamiento.
2. **Decisión humana.** Elige tú un vector de PoC de bajo impacto y apruébalo explícitamente.
3. **Ejecución supervisada.** Ejecuta la PoC (p. ej. demostrar acceso con un comando inocuo). Registra comando y resultado.
4. **Post-explotación mínima.** Enumera el sistema para demostrar impacto **sin** tocar datos ni escalar daño.
5. **Trazabilidad.** Reconstruye la línea de tiempo de la sesión: cada acción aprobada, ejecutada y su evidencia.

Ejercicios

1. ¿Por qué la decisión de explotar no debe delegarse en la IA?
2. Define 3 acciones que **siempre** requieren aprobación humana.
3. Diseña el registro mínimo de trazabilidad de una acción de explotación.
4. ¿Qué es una PoC de bajo impacto y por qué se prefiere?
5. Enumera límites de post-explotación que pondrías por escrito en las RoE.

Reto verificable

Demuestra, en tu VM, una vulnerabilidad con una PoC de bajo impacto asistido por el agente, con trazabilidad completa.

Criterio de aceptación: cada acción con impacto fue aprobada por ti antes de ejecutarse; existe un registro reproducible; no se tocaron datos reales ni se salió del alcance.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Dejar que el agente explote automáticamente	Riesgo legal y de daño. Exige aprobación humana por acción.
PoC que causa más daño del necesario	Limitate a demostrar; no escales el impacto.
No registrar lo que se hizo	Sin trazabilidad no hay informe ni defensa legal. Loguea todo.
Delegar decisiones destructivas	Nunca. Borrar/cifrar/modificar exige criterio humano explícito.
Salir del alcance "porque el agente lo sugirió"	El alcance manda sobre la IA. Corta y redefine.

Preguntas frecuentes

 **¿La IA puede explotar sola una máquina?** Técnicamente puede encadenar herramientas, pero **no debe** hacerlo sin supervisión: el riesgo legal, de daño y de salir de alcance es demasiado alto. La responsabilidad es humana.

 **¿Esto no facilita el mal uso?** La metodología aquí es de **supervisión y control**, la misma que exige un pentest profesional. El énfasis está en autorización, límites y trazabilidad — justo lo contrario del abuso.

Referencias

- PTES — Exploitation / Post-Exploitation
- MITRE ATT&CK
- kali-mcp (MIT) — <https://github.com/pabpereza/kali-mcp>
- Clase 085 (reporte) del programa.

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Clase anterior

[Clase 334 — Reconocimiento y escaneo asistidos por IA](#)

Siguiendo clase

[Clase 336 — OSINT y auditoría web con agentes de IA](#)